

EE-482: Network Security and Cryptography

LECTURES NO 14:

i. Message Authentication

ii. Public Key Infrastructure (PKI)

Engr. Tehseen Ahsan

Assistant Professor, Computer Engineering Department

HITEC University Taxila Cantt, Pakistan

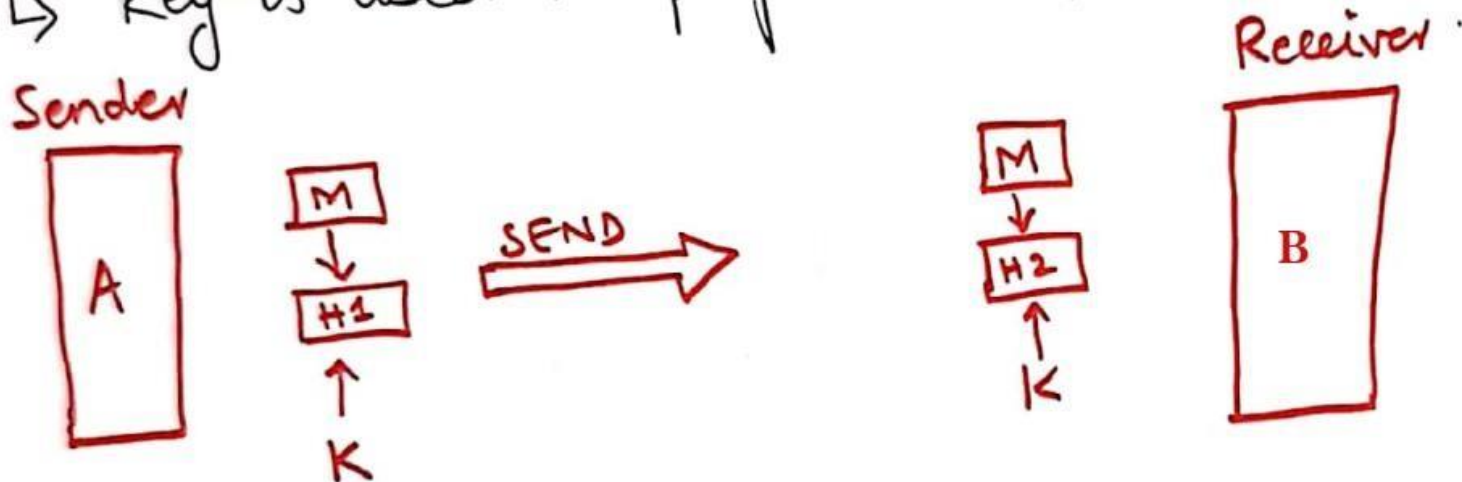
Organization of Lecture

1. MAC (Message Authentication Code)
2. Significance of MAC
3. Difference between MAC & Encryption and Decryption Process
4. HMAC (Hash-based Message Authentication Code)
5. Complete HMAC Operation
6. Limitations of HMAC
7. Public Key Infrastructure (PKI)
8. Digital Certificates
9. Certification Authority (CA)
10. Details of Digital Certificates
11. Digital Certificate Creation

1. MAC (Message Authentication Code) [1/2]

* MAC (Message Authentication Code):

- ↳ Slightly different than a message digest.
- ↳ Message digest (MD) is a fingerprint of a message & there is no cryptographic process.
- ↳ MAC requires that sender & receiver should know a shared symmetric key (Secret)
- ↳ Key is used in preparation of MAC.



1. MAC (Message Authentication Code) [2/2]

Step 1: 'A' & 'B' share a symmetric key 'K' which is not known to anyone else. 'A' calculates MAC by applying key 'K' to message 'M'.

Step 2: 'A' sends original message and MAC 'H1' to B.

Step 3: When 'B' receives message, it also uses key 'K' to calculate its own MAC 'H2'.

Step 4: 'B' compares 'H1' and 'H2'. If two match, 'B' concludes that message 'M' has not been changed during transit.

If $H1 \neq H2$; B rejects the message.

2. Significance of MAC

* Significance of MAC

- 1) MAC assures the receiver (B) that message is not altered
→ If attacker alters message, he cannot alter MAC 'H1' (as key used for HMAC generation is not known).
- 2) Receiver (B) is assured that the message indeed came from the correct sender (A). As only sender & receiver have knowledge of the secret key (K)

3. Difference between MAC and Encryption and Decryption Process

* Difference b/w MAC & Encryption/Decryption process

- ↳ In symmetric key cryptography, encryption & decryption must be reversible i.e. $E \neq D$ are mirror images.
- ↳ In case of MAC both sender and receiver perform Encryption process only.
- ↳ MAC algorithm need not to be reversible
- ↳ MAC is one way algorithm (encryption only).

4. HMAC (Hash-based Message Authentication Code) [1/4]

* HMAC (Hash-based Message Authentication Code):

- ↳ used for the IP (Internet Protocol) security.
- use either MD5 (Message Digest-5) or SHA-1 or any other message digest algorithm in intermediate steps.

* Working:-

Variables:

MD: Message Digest/hash function used (MD5/SHA-1).

M: Message whose MAC is to be calculated.

L: no. of blocks in message.

b: no. of bits in each block

K: Shared symmetric key

ipad: A string 00110110 repeated

opad: A string 01011010 repeated

4. HMAC (Hash-based Message Authentication Code) [2/4]

Step 1: Make the length of 'K' equal to b .

→ if length of $K < b$: expand the key by padding 0 bits to the left of key.

→ if length of $K = b$: do nothing

→ if length of $K > b$: Need to trim key. Pass 'K' through a special MD algorithm (H) whose output is $K = b$.

Step 2: XOR 'K' with ipad

S1 = $K(\text{length} = b) \text{ XOR } \text{ipad}(00110110)$

4. HMAC (Hash-based Message Authentication Code) [3/4]

Step 3: Append M to $S1$



$$= (\underbrace{K \oplus \text{ipad}}_{\substack{\downarrow \\ S1}}) \parallel \underbrace{M}_{\substack{\downarrow \\ \text{Message}}} \quad \text{(append)}$$

Step 4: MD algorithm

The MD algorithm is applied to output of Step 3

$$H \left[\underbrace{(K \oplus \text{ipad}) \parallel M}_{\substack{\downarrow \\ \text{output of step 3}}} \right]$$

$\downarrow$ Hash function

4. HMAC (Hash-based Message Authentication Code) [4/4]

Step 5: XOR 'K' with opad

$$\underline{\underline{S_2}} = K(\text{of step 1}) \oplus \text{opad} (01011010)$$

Step 6: Append output of step 4 to S_2 .

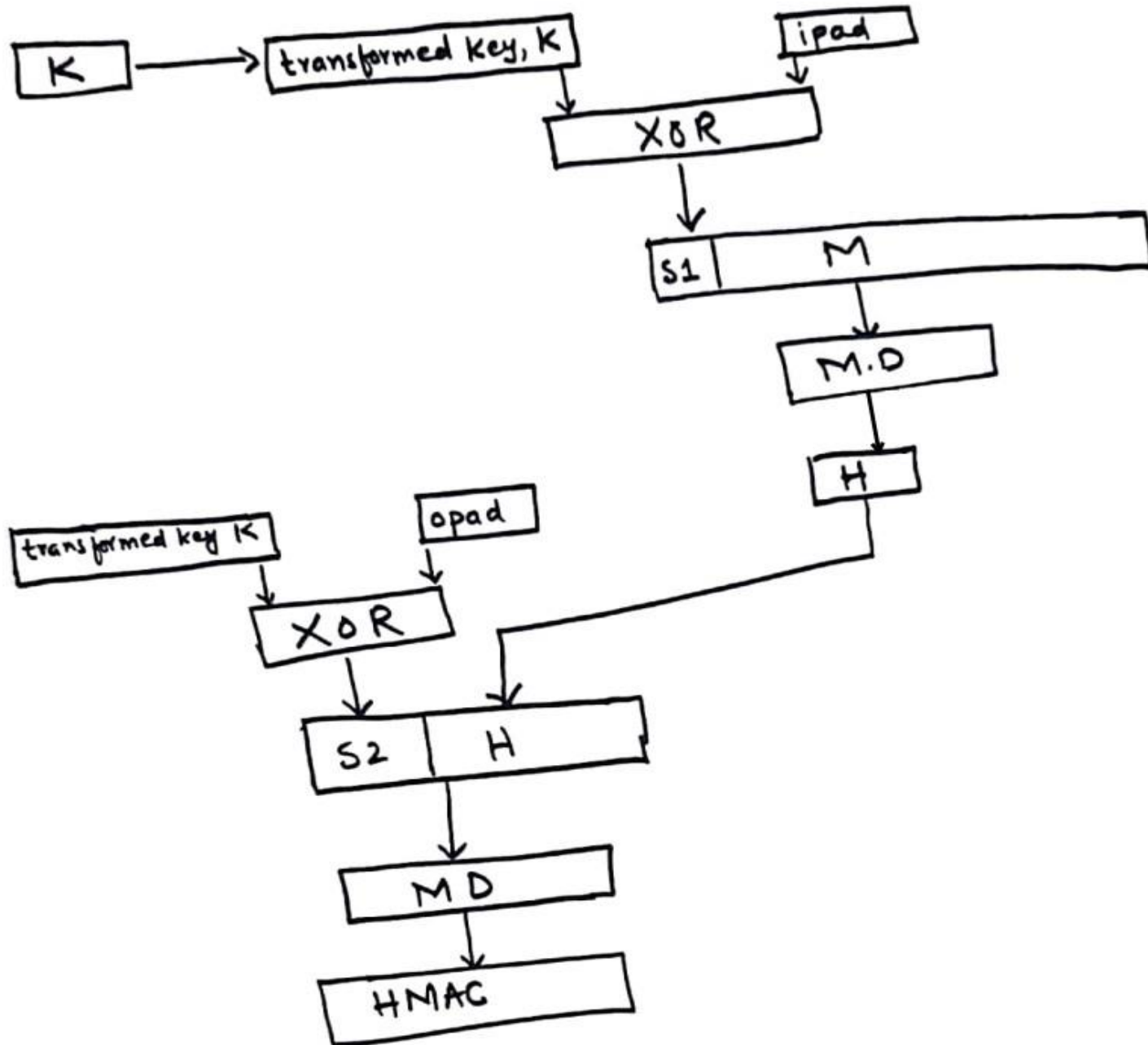
$$\underbrace{\text{M.D of step 4}} \parallel \underbrace{S_2}_{\downarrow} \rightarrow H[(K \oplus \text{ipad}) \parallel M] \parallel (K \oplus \text{opad})$$

Step 7: MD algorithm

Apply hash function to output of step 6

$$\text{MAC} = H[(K \oplus \text{opad}) \parallel H[(K \oplus \text{ipad}) \parallel M]]$$

5. Complete HMAC Operation



6. Limitations of HMAC

* Limitations of HMAC

- 1) Problem of symmetric key exchange.
- 2) How can receiver be sure that sent by original sender & not an intermediate receiver.
- 3) Repudiation (both parties have shared key)

7. Public Key Infrastructure (PKI)

* PKI:

Public Key Infrastructure consists of the components necessary to securely distribute public keys/asymmetric keys.

- ↳ PKI consists of certificates, a method for retrieving & revoking certificates and method for evaluating a chain of certificates.
- PKI is closely related to ideas of asymmetric key cryptography; mainly including message digests, digital signatures and encryption services.

8. Digital Certificates (1/4)

Digital Certificates

↳ Problem in symmetric key cryptography: Key agreement or key exchange.

↳ Solution: Asymmetric key cryptography.

↳ Issue: How do parties exchange their public keys with each other?

↳ Resolved by Digital certificates.

↳ Similar to a passport (helps in establishing our identity)

- Full name
- Nationality
- Date & place of birth
- Photograph & signature.

8. Digital Certificates (2/4)

→ Digital certificate is simply a small computer file.
can be a file with extension .cer

↳ A digital certificate signifies association b/w
Alice (say) and her public key.

↳ An authority officially approves the association b/w
a user and his digital certificate.

↳ The authority is a mutual trusted party.

↳ A digital certificate must contain a user name
and his public key to prove a particular key
belongs to a particular person.

8. Digital Certificates (3/4)

<u>Passport</u>	<u>Digital Certificate entry.</u>
Full name	Subject name
Passport number	Serial number
Valid from	valid from
Valid till	Valid till
Issued by	Issuer name
Photograph & signature	Public key

8. Digital Certificates (4/4)

- ↳ each digital certificate has a unique serial number.
- ↳ No two digital certificates issued by same issuer can have same serial number.
- ↳ who can issue the digital certificate?

9. Certification Authority (CA)

Certification Authority (CA):

A CA is a trusted agency that can issue digital certificates.

↳ A CA has to be somebody who everybody trusts.

↳ Usually a CA is a reputed organization
e.g. financial institution, software company.
Verisign, Entrust

↳ CA has the authority to issue digital certificates to individuals & organizations which want to use those certificates in asymmetric key cryptographic applications.

10. Details of Digital Certificates (1/5)

Details of digital Certificates

Standard **X.509** defines structure of a digital certificate

↳ Introduced by ITU (International Telecommunication Union) in 1988.

↳ 3 versions exist for X.509

X.509 V1

X.509 V2

X.509 V3

contains extensions or
extended attributes

10. Details of Digital Certificates (2/5)

Description of various fields in a X.509 digital Certificate

VERSION 1

<u>Field</u>	<u>Description</u>
Version	Identifies a particular version of the X.509 protocol (can be 1, 2, or 3 }
Certificate Serial no.	Contains a unique integer number generated by the CA.
Signature Algorithm Identifier	Identifies the algorithm used by the CA.

10. Details of Digital Certificates (3/5)

Issuer Name	Identifies the Distinguished Name of the CA that created and signed the certificate
Validity (not before/not After)	Contains two date values which specify the time frame within which certificate is considered valid.
<u>Subject Name</u> ↳ user/organization	Identifies the Distinguished Name of the end entity (i.e the user or organization) to whom certificate refers.
<u>Subject public key info.</u> ↳ user/organization	Contains the subject's public key and algo. related to that key.

10. Details of Digital Certificates (4/5)

EXTENSIONS:

VERSION 2.

<u>Field</u>	<u>Description</u>
Issuer Unique Identifier	Helps identify a CA uniquely if two or more CA have used same Issuer Name
Subject Unique Identifier	To identify uniquely a Subject if two or more subjects have used same subject name

10. Details of Digital Certificates (5/5)

VERSION 3

Key identifier

Key usage

Key usage Period

Certificate policies

Subject Alternate name

Issuer Alternate name

Constraints

etc.

11. Digital Certificate Creation (1/7)

* Digital Certificate Creation:

1) Parties Involved:

Subject: end user or organization

Issuer: Certification Authority (CA)

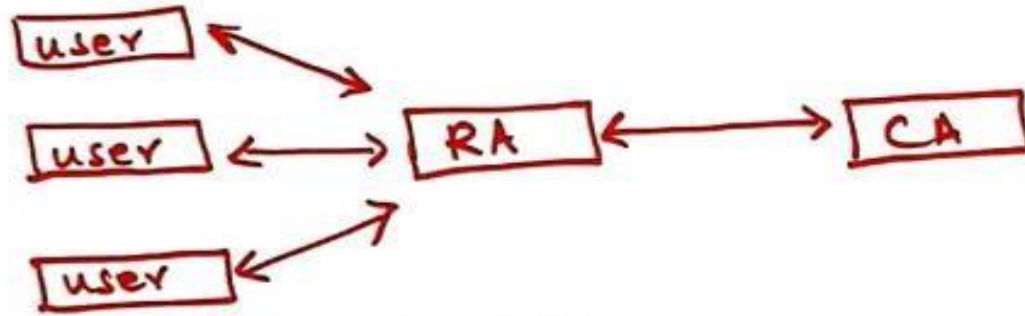
Optional Third party: Certificate creation & management

* A CA can delegate some of its tasks to a third party called Registration Authority (RA). RA assists the CA.

* To end user CA & RA appear the same.

* RA is intermediate entity

11. Digital Certificate Creation (2/7)

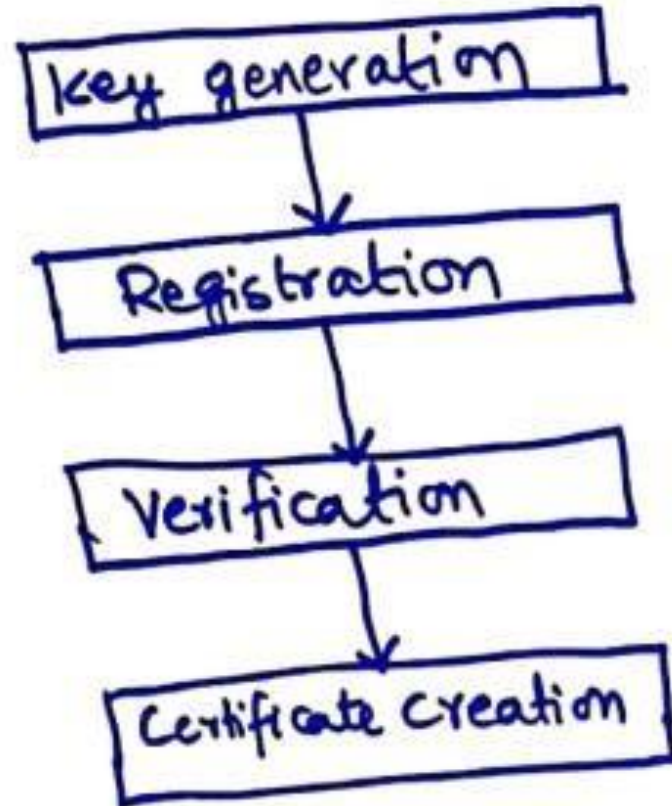


Services provided by RA:

- ↳ accepting & verifying registration info. about new users.
 - ↳ generating keys on behalf of users
 - ↳ accepting & authorizing requests for key backup & recovery.
 - ↳ accepting & authorizing requests for certificate revocation.
- ⇒ CA becomes isolated entity from the end user; hence more secure against attacks
- * RA cannot issue digital certificates; must be issued by CA.

11. Digital Certificate Creation (3/7)

2) Certificate Creation Steps:



11. Digital Certificate Creation (4/7)

Step 1: Key generation:

↳ Subject (user/organization) wants to obtain a certificate

↳ 2 approaches.

(i) Subject creates a private/public key pair using some software. Subject must keep the private key generated secret. Subject sends the public key along with evidence about himself to the Registration Authority (RA).

(ii) The RA can generate a key pair on the subject's behalf. Keys are centrally generated & distributed by the RA for ensuring security policies.

Disadvantage: RA knows about the private key. Key can be exposed to others during transit to intended user.

11. Digital Certificate Creation (5/7)

Step 2: Registration

- ↳ required only if the user generates the key pair himself
- ↳ user generates key pair & sends public key to the RA
- ↳ User also sends registration information (e.g: subject's name) & evidence about himself to RA
- ↳ The format for certificate requests has been standardized and is called Certificate Signing Request (CSR).
- ↳ The evidence may not be in the form of computer data and can consist of paper-based documents.
- ↳ User must not send his private key to the RA & must retain it securely.
- ↳ user gets a request identifier for tracking the progress of the certificate request.

11. Digital Certificate Creation (6/7)

Step 3: Verification

↳ The RA has to verify user's credentials.

↳ RA needs to check that user who is requesting certificate does indeed **possess** the private key corresponding to the public key.

⇒ This check is called Proof of Possession (PoP) of private key.

(i) RA can demand user digitally sign her CSR using his private key → RA can verify using public key.

(ii) RA can encrypt the certificate with user's public key → user can obtain certificate by decrypting with private key.

11. Digital Certificate Creation (7/7)

Step 4: Certificate Creation

- ↳ RA passes details of the user to the CA.
- ↳ CA creates a digital certificate for the user using programs for X.509 standard format.
- ↳ CA sends the certificate to user and also retain a copy of the certificate for its own record.
- ↳ CA's copy of certificate is maintained in a certificate directory: central storage location maintained by the CA.

Q: Why trust Digital Certificates?

- ↳ CA always signs digital certificate with its private key.
- ↳ Use CA's public key to verify the signature.

References: Textbooks

1. *“Cryptography and Network Security”, by Behrouz A. Forouzan, Debdeep Mukhopadhyay, 2nd Edition, McGraw Hill Education (India) Private Limited.*
2. *“Cryptography and Network Security Principles and Practice”, by William Stallings, 6th Edition, Pearson.*
3. *“Computer Security Principles and Practice”, by William Stallings, Lawrie Brown, 4th Edition, Pearson.*